GOOGLE CLOUD ZERO-TRUST AI SECURITY & ISO/IEC 42001 AIMS GOVERNANCE PLATFORM

Assurance, Governance & Continuous AI Auditing

End-to-end platform to assess, audit, and harden Enterprise Artificial Intelligence Architectures (GenAI, LLMs, Autonomous Agents, MCP & RAG) under global standards **OWASP AI-SVS v1.0 (Level L2/L3)** and **ISO/IEC 42001:2023**.

OWASP AI-SVS V1.0 (12 CHAPTERS) | ISO/IEC 42001:2023 AIMS | CLOUD IAP ZERO-TRUST EDGE (C04.3) | VERTEX AI GEMINI 3.8 FLASH (KEYLESS ADC) | SHA-256 NORMATIVE INTEGRITY (C01.4) | CRESCENDO GUARDRAILS (C02.10) & ANTI-DOW (C11.1)

THE PROBLEM TO SOLVE

The Critical Security Blindspot in Enterprise GenAI Adoption

Enterprises are shipping generative AI models, agentic workflows, MCP tools, and RAG pipelines without architectural verification or ISO 42001 governance.

⚠ Accelerated Ungoverned Deployment

13% of organizations already reported breaches of AI models or applications, and **97%** of those lacked proper AI access controls (IBM, 2025).

⚠ Multi-Turn & Agentic Attack Surface

RAG pipelines, MCP servers, and autonomous agents introduce critical vectors: **Multi-Turn Crescendo Prompt Injection** (`C02.10`), **Normative/Vector Poisoning** (`C01.4`), and SSRF/IMDS exfiltration (`C04.3`).

⚠ CISO vs Data Science Silo

Security teams lack tools to audit agent graphs, MCP manifests (`C10.1`), and pre-retrieval vector ACLs (`C08.1`); AI developers lack automated mappings to formal compliance clauses.

Lack of Operationalized Governance (ISO/IEC 42001)

Organizations struggle to operationalize **ISO/IEC 42001:2023** requirements—such as Corporate AI Policies (`A.2.1`), Confidential Whistleblowing (`A.3.3`), AI Asset Inventories (`A.4.1`), and Human Verdict Appeals (`A.5.2`)—into software engineering workflows.

Proliferation of "Shadow AI" & Denial of Wallet

Unregulated external API calls, timing-vulnerable token checks (`C05.3`), over-privileged service accounts (`C05.2`), missing Anti-DoW token budgets (`C11.1`), and exposed logit probabilities (`C11.4`).

Source: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

IMPACT OF INACTION

The Real Cost of Neglecting Proactive AI Assurance

Operating unverified AI systems exposes organizations to severe financial, regulatory, and operational liabilities.

€35M
or 7% of global annual turnover in statutory EU AI Act penalties

$4.88M
Average global cost of an enterprise data breach (IBM Security 2024)

13%
of organizations reported breaches of AI models or apps (IBM 2025)

97%
of those lacked proper AI access controls (IBM 2025)

Exfiltration of Secrets, IMDS & PII

Multi-turn crescendo jailbreaks and SSRF payloads engineered to extract cloud metadata (`169.254.169.254`), API keys, or cross-tenant records when pre-retrieval ACLs (`C08.1`) are absent.

Regulatory Injunctions & Non-Conformity

Failure to demonstrate ISO/IEC 42001 AIMS controls, GDPR/LFPDPPP ARCO cascading deletion, or LFPC Art. 56 cooling-off mechanisms triggers mandatory shutdowns and statutory fines.

Unappealable Algorithmic Harm

Hallucinated compliance verdicts or biased automated decisions without human-in-the-loop appeal channels (`ISO 42001 A.5.2`) or ethics whistleblowing (`A.3.3`) erode institutional trust.

OUR SOLUTION

AegisAI: Comprehensive & Automated AI Assurance

Transforming AI security and ISO 42001 governance auditing from weeks of manual review into deterministic, evidence-backed verification.

🛡 Shift-Left Multi-Standard Verification

AegisAI inspects architecture documents, PDFs, ZIP bundles, microservice specs, and live GCP telemetry against **OWASP AI-SVS v1.0** and **ISO/IEC 42001:2023** simultaneously.

- Deterministic Map-Reduce evaluation with strict chapter enum schemas (`buildBatchChaptersSchema`).
- Mandatory verbatim citation grounding (`textoEvidencia` & `fuenteEvidencia`).
- Pre-inference DLP masking and C02.10 multi-turn crescendo prompt injection blocking.

⚡ 100% Remediated Architecture & Full Cookbook

Beyond diagnostics, AegisAI synthesizes a complete **Drop-in Replacement Architecture Specification** (Section 3) plus a full, untruncated **Patch Cookbook** (Section 4) for every finding.

- Renders all `1..N` non-passing controls without truncation, even on 35+ finding multi-standard audits.
- Sentence-boundary summary extraction and accurate syntax tags (`typescript` , `hcl` , `yaml` , `python` , `bash`).
- Executive PDF & Markdown exports ready for certification auditors and engineering teams.

1. Cryptographic Integrity (C01.4)

Normative snapshots verified at startup against a SHA-256 manifest (`integrity-manifest.json`).

2. Keyless GCP Live Scanner (C05.2)

Read-only inspection of Vertex AI, Cloud Run, IAM & Secret Manager using ephemeral caller credentials.

3. Continuous AIMS Telemetry (C08.4)

Real-time KPI tracking of citation grounding coverage, JSON schema fidelity, and control posture.

COMPLIANCE MATRIX

Multi-Standard Framework Support & ISO/IEC 42001 AIMS

Simultaneous evaluation across global technical security standards, management systems, and regional privacy statutes.

Standard / Framework	Technical & Governance Scope	Key Controls Verified & Enforced by AegisAI	Assurance Level
OWASP AI-SVS v1.0	AI Security Verification Standard (12 Chapters)	`C01.4` SHA-256 Manifest, `C02.10` Crescendo Guard, `C04.1` Read-Only Container, `C04.3` Cloud IAP & SSRF Block, `C05.2–C05.4` Constant-Time Auth & IAM, `C08.1/C08.4` RAG ACLs, `C09.4` Sagas, `C10.1–C10.5` MCP Security, `C11.1/C11.4` Anti-DoW & Logprobs Off, `C12.2` SIEM Alerts.	L1 / L2 / L3 READY
ISO/IEC 42001:2023	AI Management System (AIMS Clauses 4–10 & Annex A)	`Clause 4.1/4.2` Context & Stakeholders, `Clause 5/A.2.1/A.2.3` Corporate AI Policy, `Clause 7/A.3.3` Competency & Whistleblowing, `A.4.1` AI Asset Inventory, `A.5.1–A.5.3` Impact Assessment & Human Appeal, `Clause 9` KPIs & Internal Audit, `A.9.1/A.9.2` Acceptable Use.	54 CONTROLS
Mexican Regulatory (2026)	Consumer Protection (LFPC) & Personal Data (LFPDPPP)	Algorithmic transparency, deceptive commercial pattern prevention, Art. 56 5-day cooling-off retraction, ARCO cascading deletion, and DLP PII masking.	REGIONAL STATUTORY
BYOF Custom Framework	*Bring Your Own Framework* (Multi-Tenant)	Admin-authenticated ingestion (`C05.3`) with SHA-256 integrity checks (`C01.4`) and pre-retrieval tenant domain ACL filtering (`allowedDomains` , `C08.1`).	TENANT ISOLATED

Unified Cross-Framework Map-Reduce: Evaluates 103+ combined OWASP AI-SVS & ISO/IEC 42001 controls in parallel batches using constrained chapter ID enums so ISO Clauses 9/10 and Annex A.9/A.10 never collide with OWASP C09/C10.

SOFTWARE ARCHITECTURE

4-Layer Zero-Trust & Defense-in-Depth Architecture

Hardened serverless architecture deployed on Google Cloud Run behind Identity-Aware Proxy (IAP) with keyless Vertex AI inference.

1. Perimeter & SPA

- **Cloud IAP** (`--no-allow-unauthenticated`)
- **React 19 + TS + Vite**
- Firebase Auth OAuth 2.0 domain allowlist (`google.com` , `example.com`)
- Embedded ISO 42001 Policy, Appeal (`A.5.2`) & Whistleblowing (`A.3.3`) UI

2. Hardened API Layer

- **Read-Only Container** (`chmod -R a-w /app` , `C04.1`)
- Constant-time token check (`crypto.timingSafeEqual` , `C05.3`)
- Firebase Admin `verifyIdToken()`
- DNS Rebinding Guard (`C10.5`) & MCP Signature Verifier (`C10.1`)
- Anti-DoW Quotas (`C11.1`)

3. AI Engine & Guardrails

- **Vertex AI** (`gemini-3.8-flash`) via keyless ADC
- Least-privilege SA (`aegis-runner-sa` : zero `roles/viewer` , `C05.2`)
- Multi-Turn Crescendo Detector (`C02.10`)
- `responseLogprobs: false` (`C11.4`)
- Outbound SSRF/IMDS Block (`C04.3`)

4. Data, Integrity & Sagas

- **Cloud Firestore** (`aegis-ai-db`) via Admin SDK
- 308/308 tested `firestore.rules`
- Immutable audits (`allow delete: if false`) & `ownerUid` ACLs (`C05.4`)
- SHA-256 Manifest (`C01.4`)
- Compensating Sagas (`C09.4`)

Zero-Trust Isolation & Structured Security Alerting (C12.2):

Runtime state writes exclusively to Firestore (`system_config/admin_settings`) and ephemeral `/tmp/aegis-runtime-cache` . Every security event (prompt injection escalation, SSRF block, token mismatch, DoW quota breach, saga rollback) emits a structured JSON alert (`aegis-security-alerting-c12-2`) to Google Cloud Logging.

OPERATIONAL EXECUTION

The Auditor's Workflow: From Ingestion to 100% Hardening

Six-stage deterministic assurance lifecycle with built-in human oversight and automated code remediation.

1 **Authenticated Ingestion & Pre-Flight Guardrails**
Corporate user (verified via Cloud IAP + Firebase ID Token) uploads PDFs/ZIPs/specs; `inspectPromptAndTrackSession` (`C02.10`) and DLP masking sanitize input.

2 **SHA-256 Verified & Tenant-Filtered Context**
Normative snapshots verified against `integrity-manifest.json` (`C01.4`) and custom frameworks filtered by `tenantDomain` (`C08.1`) are loaded.

3 **Deterministic Vertex AI Map-Reduce Evaluation**
`gemini-3.8-flash` (`temperature: 0.0` , `responseLogprobs: false` , 180s timeout) evaluates each batch under strict chapter enum schemas.

4 **Executive Dashboard & Human Appeal (ISO A.5.2)**
Interactive radar charts, L1/L2/L3 maturity breakdown, and direct Verdict Appeal / Human Review workflow (`ai-appeals@aegisai.enterprise`).

5 **100% Remediated Architecture & Full Cookbook**
Synthesizes Section 3 drop-in architecture + Section 4 Cookbook for all `1..N` findings with accurate syntax tags (`typescript` , `hcl` , `yaml` , `python` , `bash`).

6 **Immutable Persistence & Compensating Saga**
Saved to Firestore with `ownerUid` / `tenantDomain` attribution (`C05.4`), `runCompensatingSaga` rollback safety (`C09.4`), and AIMS KPI recording (`C08.4`).

ARCHITECTURE SPECS & DEVSECOPS VERIFICATION

Verified Security Benchmarks & Production Posture

Continuously validated through automated Firestore rules tests, OWASP AI-SVS verification harnesses, and Cloud Run preflight checks.

308/308
Cloud Firestore Security Rules unit tests passed (`projects:test`)

6 / 6
Normative snapshots verified via **SHA-256** manifest at startup (`C01.4`)

0
Leaked secrets or broad IAM roles (`roles/viewer` pruned, `C05.2`)

100%
Untruncated patch cookbook generation across all 35+ multi-standard controls

Hardened Cloud Run & Container Posture

- **Immutable Container (C04.1):** Non-root `aegisuser` with `chmod -R a-w /app` .
- **Zero-Trust Perimeter (C04.3):** Cloud IAP + `--no-allow-unauthenticated` + VPC private egress + SSRF/IMDS blocker.
- **Secret Manager & Constant-Time Auth (C05.3):** Mounted `ADMIN_API_TOKEN` verified via SHA-256 + `crypto.timingSafeEqual` .
- **Anti-DoW FinOps Protection (C11.1):** Per-user sliding-window rate limits, concurrency caps (3), and 500k 24h token budgets.

Observability, Privacy & AIMS Governance

- **Structured Cloud Logging (C12.2):** Real-time `WARNING` / `CRITICAL` alerts (`aegis-security-alerting-c12-2`).
- **Continuous AIMS Telemetry (C08.4 / Clause 9.1):** Live citation grounding & schema fidelity metrics at `/api/admin/aims-telemetry` .
- **Zero Data Retention (ZDR):** Vertex AI enterprise privacy guarantees.
- **Bilingual Documentation Suite:** 8 English & 8 Spanish Manuals + ISO 42001 AIMS Manual compiled to PDF.

END-TO-END REMEDIATION TRACEABILITY

OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Controls Enforced

Comprehensive architectural and governance controls implemented across code, container, cloud perimeter, and AIMS policies.

OWASP AI-SVS v1.0 Technical Controls (17 Hardened Domains)

- **C01.4 Normative Integrity:** `verifyNormativeSnapshotsIntegrity()` SHA-256 manifest check at startup.
- **C02.10 Crescendo Defense:** `inspectPromptAndTrackSession()` multi-turn escalation blocker (HTTP 422).
- **C04.1 & C04.3 Infrastructure:** Read-only `/app` (`chmod -R a-w`), Cloud IAP, VPC egress & `validateOutboundEndpoint()` SSRF/IMDS block.
- **C05.2, C05.3 & C05.4 Auth/IAM:** Pruned `roles/viewer` on `aegis-runner-sa` , `crypto.timingSafeEqual` , Firebase ID token verification & Firestore `ownerUid` ACLs.
- **C08.1 & C08.4 RAG/Grounding:** Tenant domain ACL pre-filtering & continuous grounding telemetry.
- **C09.4 & C10.1–C10.5 Agents/MCP:** `runCompensatingSaga()` rollback, MCP Ed25519/HMAC manifest verification, OAuth 2.1 PKCE & `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` & `emitSecurityAlert()` .

ISO/IEC 42001:2023 AIMS Governance Controls (18 Clauses & Annex A)

- **Clause 4.1 & 4.2 Context & Stakeholders:** Formal internal/external issue matrix, societal role as AI assurance provider & stakeholder mapping.
- **Clause 5.1, 5.2, A.2.1 & A.2.3 Leadership & AI Policy:** Executive-approved Corporate AI Policy with annual revision cycle.
- **Clause 7.2, 7.3 & A.3.3 Competency & Whistleblowing:** Mandatory role training & confidential ethics reporting (`ai-ethics-whistleblower@aegisai.enterprise`).
- **A.4.1 Resource & Tooling Inventory:** Cataloged models, normative corpora, runtime SAs & KMS secrets.
- **A.5.1, A.5.2 & A.5.3 Impact Assessment & Appeals:** Formal AIIA methodology, quantitative risk thresholds & human appeal channel (`ai-appeals@aegisai.enterprise`).
- **Clause 9.1–9.3 & A.9.1/A.9.2 Assurance & Use:** Continuous KPIs, semi-annual internal audits, management review & acceptable use notices.

EVOLUTION & ROADMAP

Next Horizons in AegisAI Platform Engineering

Our forward-looking roadmap to advance autonomous enterprise AI assurance and regulatory automation.

Q4 2026 • NEAR TERM

Native CI/CD Shift-Left Gates

Official **GitHub Actions** and **GitLab CI Runners** to automatically block pull requests introducing prompt injection vulnerabilities, unsigned MCP manifests, or unencrypted vector storage before merging.

Q1 2027 • MEDIUM TERM

Multi-Agent Graph Auditing

Specialized auditing module for complex autonomous agent workflows (LangGraph, CrewAI, AutoGen): tool authorization boundary checks, compensating saga verification, and inter-agent memory sandboxing.

Q2 2027 • LONG TERM

Autonomous IaC Remediation

One-click automated synthesis of **Terraform Modules** and **Helm Charts** that directly apply Cloud IAP, VPC Service Controls, and Cloud Armor remediation recipes to cloud clusters.

🎯 Conclusion: Security & Governance that Accelerate Innovation

AegisAI provides the **architectural certainty, cryptographic integrity, and ISO/IEC 42001 governance** needed for enterprises to deploy frontier AI systems on Google Cloud with complete confidence.

Contact: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI